Course 2

GDPR - explained

Personal information – technology impact

- **Amount** of collected data
- **Speed** of transmitting
- **Duration** of storing info



Quiz

1. What is GDPR?
2. When it was introduced?
3. What?

GDPR



General Data Protection Regulation

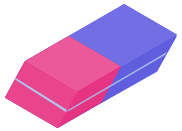


25th May, 2018



99 Articles

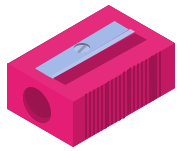
IN BRIEF



Right to Be Forgotten



Personal & sensitive Data



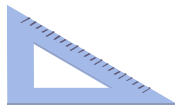
Right to Restrict Data Processing



Explicit Consent



Data Controller



Data Protection Officer

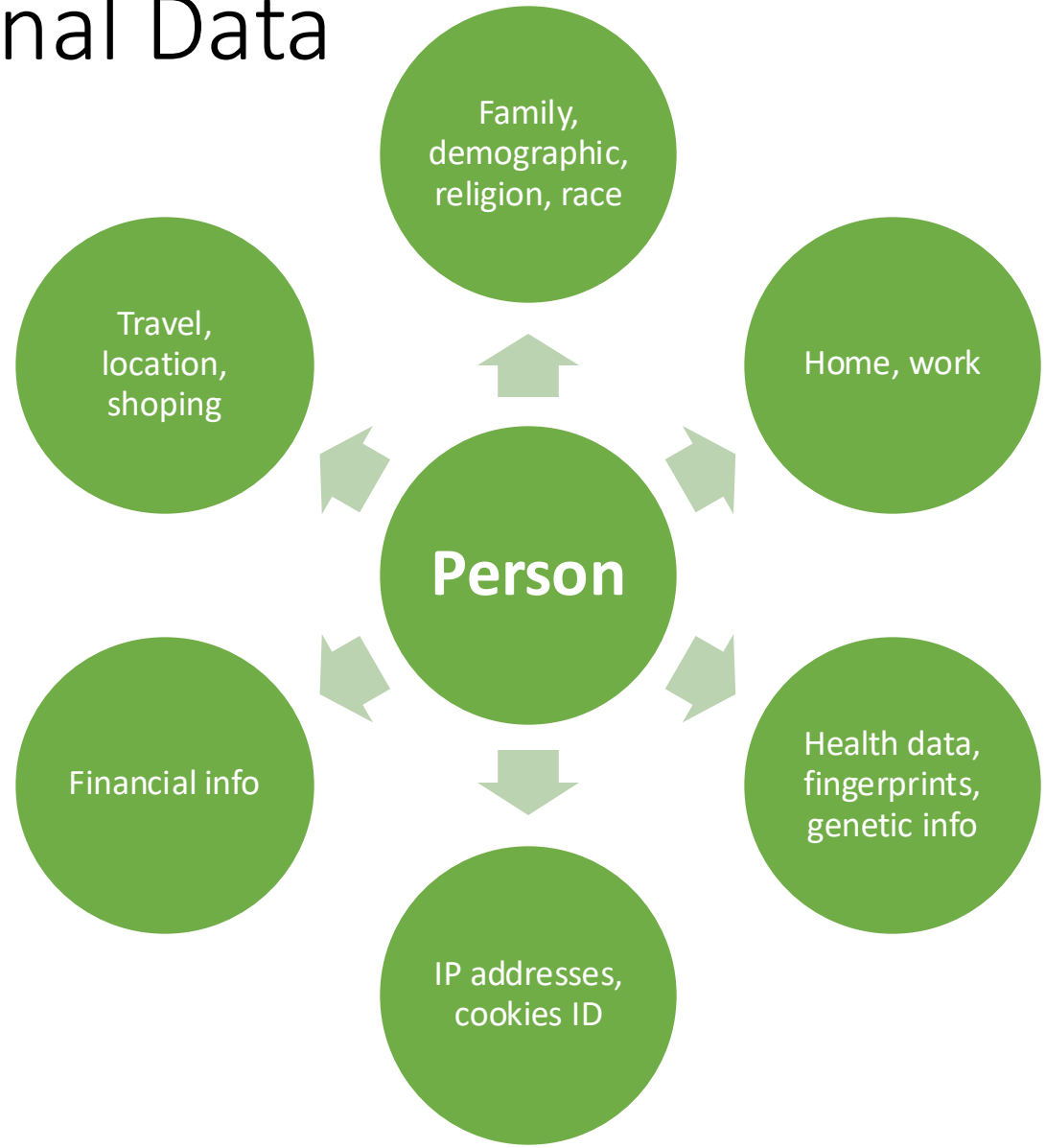
GDPR

GDPR clarifies where responsibility for privacy protection lies with any companies who **collect**, **store**, **manage** and **analyze** any form of **Personally Identifiable Information** (PII)

Applies to **any organization** (including those outside the EU) that holds or processes data from EU residents:

Stakeholders: legal, organizational, procedural, technical	Departments: HR, marketing, financial, customer services,…

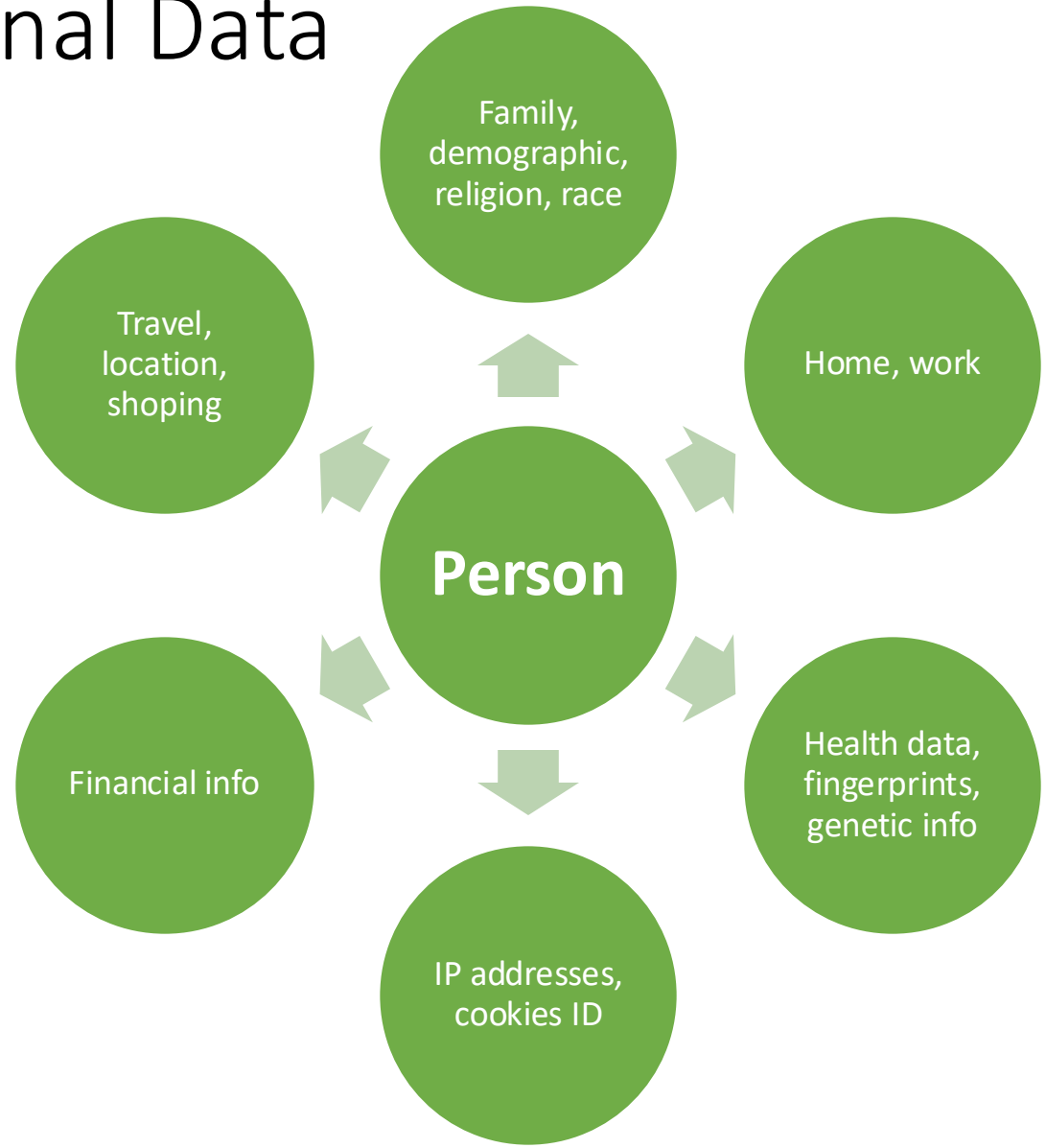
Personal Data



Impact of GDPR on personal privacy

- Access personal data
- Correct errors in personal data
- Erase personal data
- Object to processing of personal data
- Export personal data

Personal Data



Impact of GDPR on organizations:

- Protect personal data using appropriate security
- Notify authorities of data breaches within 72 hours
- Obtain appropriate consents before processing data
- Keep records detailing data processing

TRANSPARENCY:

- Provide clear notice of data collection
- Outline processing purposes and use cases
- Define data retention and deletion policies

Personal Data



Impact of GDPR on data control

- Train privacy personnel & employee
- Audit and update data policies
- Employ a Data Protection Officer (recommended)
- Create & manage compliant vendor contracts

Data Controller vs. Data Processor

	Controller	Processor
Who	natural or legal person, public authority, agency or other body	natural or legal person, public authority, agency or other body
How	Alone or jointly with others	-
What	Determines the purposes and means of the processing	Processes personal data on behalf of the controller
What	Wider legal obligations	Accountability obligations

DPO (Data Processor Officer)

- MANDATORY if:
  - You are a **public authority**
  - You are **performing large-scale constant and systematic monitoring** activities involving personal data
  - You are **processing large amounts of sensitive data** (e.g. racial, ethnic or religious profiling, belonging to a union, genetic, biometric, health data, previous convictions, etc.)

- Romania, recommended anyway (ANSPDCP)



DPO (Data Processor Officer) tasks:

- **inform** and **advise** the operator and its employees on the requirements of the GDPR
- **monitor** the operator's compliance with the GDPR
- **advise** the operator regarding the Data Protection Impact
- Assess and oversee their execution
- **cooperate** with the local DPA (Data Protection Authority)
- **notify** data subjects of breaches

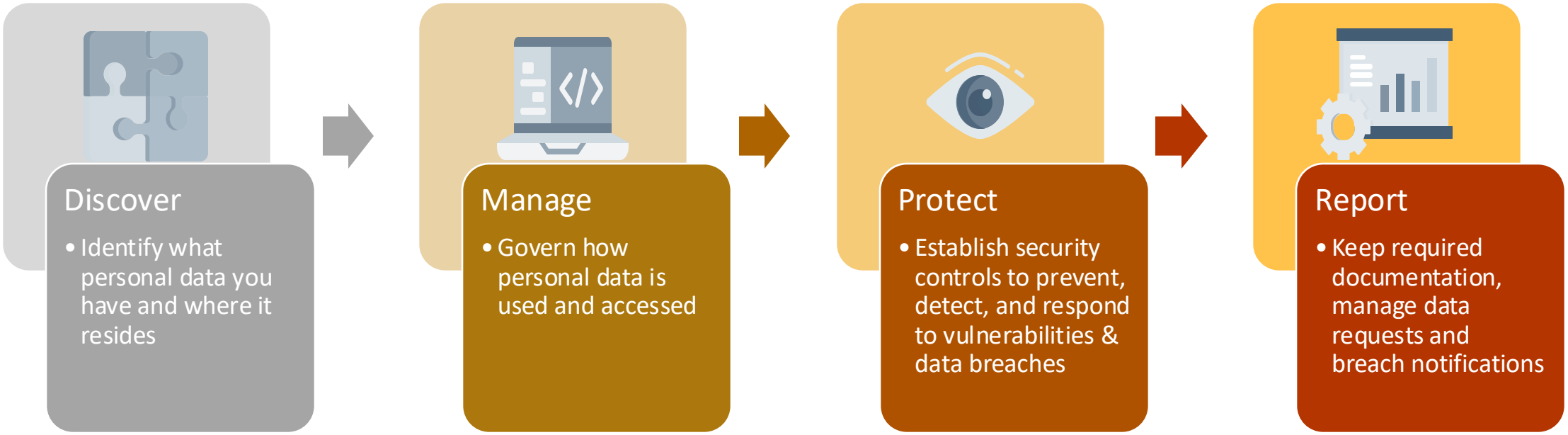


Example: University DPO https://www.ubbcluj.ro/ro/politici/

- Students' personal data:
  - What:
  - How:
  - How long:
- Staff personal data:
  - What:
  - How:
  - How long:
- Communication

ANSPDCP
(https://www.dataprotection.ro/)

GDPR Compliance



Fines

- https://www.enforcementtracker.com/

Digital media impact

Collecting personal data from users

Email marketing

User data – right to be forgotten

Respect cookies policy

Need of explicit consent

Monitoring users through **behavior tracking** tools needs to be clearly stated

Cases

Case 1: Personal privacy

- Professor X teaches a course on social issues in computing to master students
- Approximately half of the students are computer science (CS) students, whereas the other half are students majoring in other fields.
- At the first class, Professor X asks students to fill out an index card on which they include information about their major, the names of any previous CS courses they may have taken (if they are non-CS majors), their preferred e-mail address, and what they hope to acquire from the course. Professor X then records this information in the electronic grade book.

Q1: Has Professor X done anything wrong?
Q2: For which purposes can prof. X use the information?

Case 2 **Request for removal**

John Doe has requested to have his credit cards cancelled and all his information removed from his bank's system.

Q1: Is it legal? Why?

Q2: Imagine a bank software system. How this could be implemented?

Case 3: Data Pseudonymization

- This a requirement imposed in GDPR
- Imagine on situation in which this requirement is applicable, and describe two actions for fullfilling it

Case 4: Right to Rectification

[adapted from https://iacp.ie/files/UserFiles/Members-Area/Data-Protection/IACP-GDPR-Case-Studies.pdf]

- An Employer requested a psychological assessment be carried out on an employee to determine their ability to return to the workplace after a period of absence on sick leave.
- The person concerned had received a copy of the medical report in question from the medical practitioner who carried out the assessment and considered the contents to be inaccurate.
- The complainant then requested that the report be rectified to reflect what she considered to be an accurate description of their circumstances.
- The data controller, a consultant psychiatrist, reverted to the data subject stating that it was not possible to make the kind of alterations to the independent medical assessment that had been sought.
- Q1. Do you agree with the medical practitioner, why?
- Q2. What alternative solutions could be taken if any?

Case 5: Travelodge

- June 2018: Travelodge customer database has been breached. The database was managed by a 3rd party company Typeform.

Q1: Who is responsible and who should be fined?

Q2: What should Travelodge do?

Q3: What should Typeform do?